ITAC 2026 — Final Round

Stonewake — Software Test Plan & Software Test Report

STP (testing strategy) and STR (execution results, product defects, insights) in one document

Field	Value
Author	Yuval Menashe (ITAC 2026 finalist). AI assistance: Claude Code; see README and docs/AI_USAGE.md
Date / version	4 Nov 2026 · v2.0 (built 04 Nov 2026 20:30 Asia/Jerusalem)
System under test	Stonewake dashboard app.stonewake.ai and REST API api.stonewake.ai (production, v1.0.0 per /health)
Inherited project	AlexKomanov/stonewake-final-repo @ b4f92c9 (10 API + 10 UI tests)
Submission repository	https://github.com/meyuval/itac-finals
GitHub Actions	https://github.com/meyuval/itac-finals/actions
Public execution report	https://meyuval.github.io/itac-finals/
Defect tracker	SpiraTest, product 35 "Yuval Menashe": IN:81, IN:82, IN:83 (links in §12)
Bug evidence	Jam.dev: https://jam.dev/c/ec59a5c7-7b62-4431-ad46-8dbd12b42303 (IN:81)

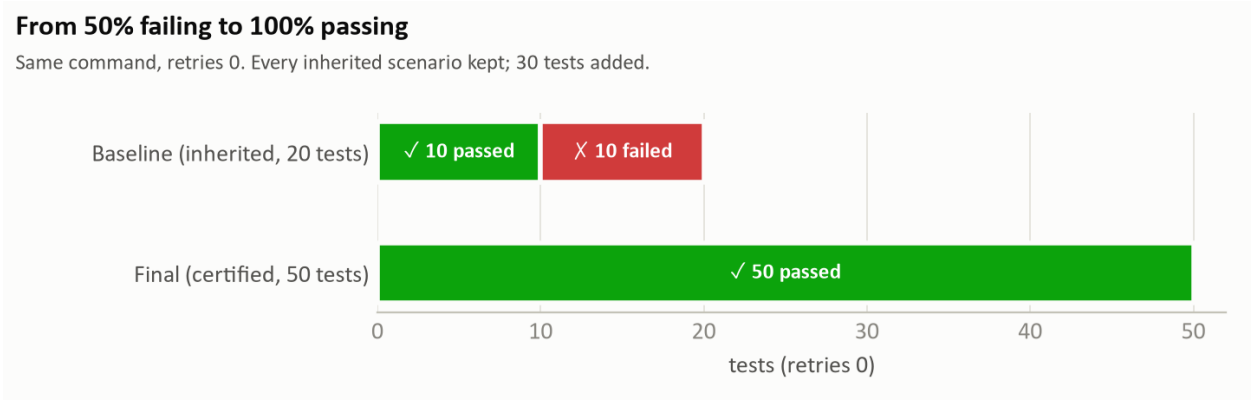
1. Executive summary

We inherited a Playwright + TypeScript project with **20 tests, 10 of them failing on every run**. Credentials were committed, there was no structure, no injected configuration and no public report. Triage showed that **nine of the ten failures were automation defects** (wrong path, auth scheme, field, expected value, brittle selectors). The tenth exposed a real product gap (IN:83). We fixed the root causes without weakening a single inherited assertion. We refactored the suite into layers (infrastructure / business / tests) and grew it to **50 tests** (24 API, 26 UI), covering UI–API data parity. Retries are disabled, so a green run means every test passed on its first attempt.

Testing the product itself found **3 product defects**, all filed in SpiraTest with deterministic steps, expected/actual results and environment: **0 Critical, 0 High, 2 Medium, 1 Low**. The most important (IN:81) breaks a documented security promise: the key-management endpoint reveals why a credential was refused.

Go / No-Go (product): CONDITIONAL GO. No defect blocks a core user journey and no data is exposed. IN:81 should be fixed before the API-key management surface is promoted, because it contradicts the published uniform-refusal contract. IN:83 hides two enabled modules (EDD Dossiers, Signals) from navigation. **Automation suite: trustworthy.** It passed five consecutive full runs on one frozen commit, with retries 0 and no skips (§11.2).

50	5/5	0	3
tests (from 20), none dropped	consecutive green CI runs	retries · flaky · skipped	product defects in SpiraTest



Key insights at a glance

1. 9 of 10 inherited failures were test bugs, not product bugs. Checking each one against the docs and the live product kept SpiraTest free of false positives.

2. The most serious bug was on a less-travelled surface. /v1 honours the uniform-401 contract; /org/api-keys reveals why a credential was refused (IN:81).

3. Release notes drift from the build. The 4 Nov changelog promises sidebar entries that are missing (IN:83).

4. UI–API parity tests catch what neither layer sees alone. The same record is read from the API and asserted in the dashboard.

5. Stability came from removing guesswork, not adding retries. No sleeps, semantic locators, one sign-in, retries 0. Five green means five real first-attempt passes.

6. Evidence needs a privacy review. A Jam recording first exposed an API key in Swagger's curl panel; it was deleted and re-recorded with the key masked.

Full reasoning for each insight is in §15.

Part A — Software Test Plan (STP)

2. Scope and assumptions

In scope. Dashboard: sign-in, terms gate, session boundary and sign-out; sidebar navigation to all nine modules; Deal Book list, search, deal page and downloads; Countries; Institutions and company page; Portfolio tiles and rows; Monitoring views. REST API (read-only /v1): health, identity and rate-limit headers, authentication boundary, portfolio list/summary/pagination, institutions, countries, deals, research, search and input validation. Cross-layer: the same record must match in the dashboard and the API.

Out of scope (with reason). The MCP server and the network canvas graph (time budget). UI writes such as adding a monitored company, because a write would change the counts the parity tests compare. Admin-only writes (API keys, SCIM, SSO), which the contestant account cannot perform. Cross-browser runs: Chromium only, so that five full certification runs fit before the deadline. Visual, accessibility and performance testing (next-step backlog, §16).

Assumptions. A1: one competition account in a shared workspace. A2: workspace data is live test data and may change, so assertions avoid pinning live counts. A3: the 4 Nov changelog describes the product as deployed. Where it does not, the difference is a finding, not an assumption.

3. Testing strategy

- **Risk-based, preserve then extend.** Each of the 20 inherited scenarios was kept and traced to a new spec (an `// inherited:` comment in the code). New coverage was chosen by business risk (§4), not by count.
- **Three layers.** (1) API contract tests against the OpenAPI spec and the published error/auth docs. (2) UI functional tests through page objects. (3) Parity tests that read a record from the API and assert that the dashboard shows the same value. They catch defects neither layer sees alone.
- **Live product, no mocks.** Every test hits production, so a failure can be a real defect. Every test is read-only, so no cleanup is needed and runs cannot interfere.
- **Documentation as oracle.** Expected results come from docs.stonewake.ai (errors, authentication, keys), the OpenAPI spec and the changelog. A difference between the docs and the observed behaviour is triaged before anything is called a bug.
- **Triage before filing.** Every failure is classified as **A** (automation defect), **P** (product defect) or **U** (unknown). Only confirmed P items go to SpiraTest, with Jam.dev evidence where recording was possible. One candidate (API "mojibake") was disproved and not filed (§14).
- **Exploratory + automated.** Manual probes (curl, API explorer, browser) were used to explore and to reproduce. The automated suite holds the regressions.
- **Evidence over assertion.** Retries 0. Five consecutive green full-suite GitHub Actions runs on one frozen SHA. A public HTML report per run, stamped with the run number and commit.

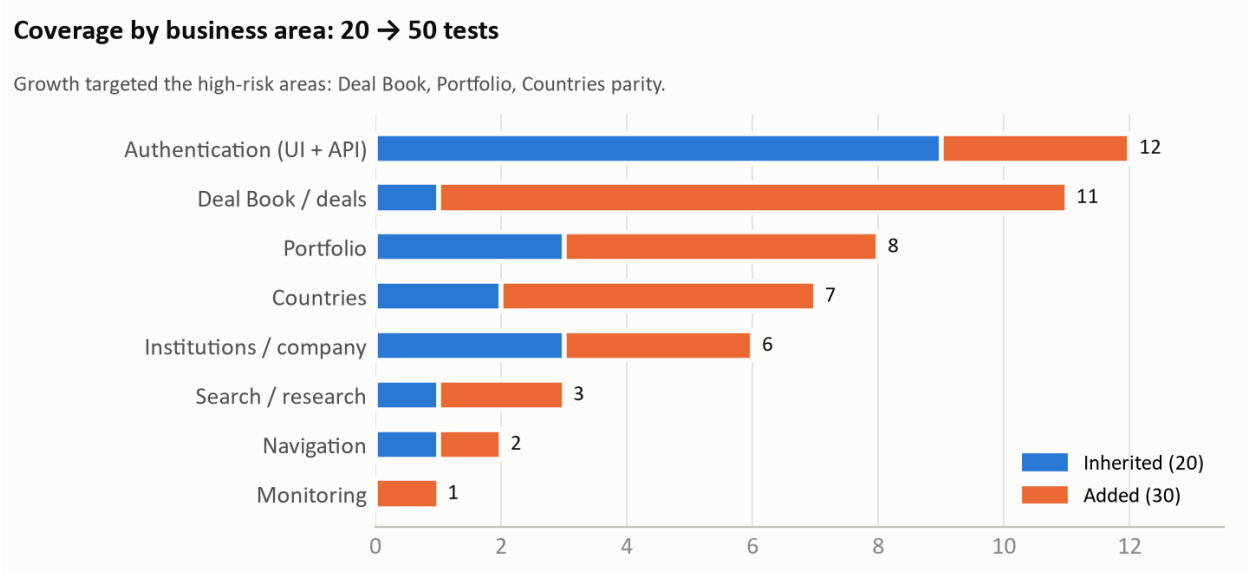
4. Risk analysis and priorities

#	Area	Risk if broken	Priority	Coverage
R1	Sign-in, terms gate, session, sign-out	nothing works; data exposure	High	ui/auth.spec.ts (5)
R2	API authentication boundary	data exposure	High	backend/health-and-auth.spec.ts (7)
R3	Deal Book: list, search, deal page, downloads	core workflow broken	High	ui/deal-book*.spec.ts (7), backend/deals.spec.ts (4)
R4	Portfolio statuses; summary vs list consistency	wrong credit colour shown	High	backend/portfolio (4), ui/portfolio (4)
R5	Countries risk record; UI/API parity	wrong country risk	Med-High	backend/countries (3), ui/countries (4)
R6	Institutions / company page	wrong counterparty	Medium	backend/entities (3), ui/institutions (1), ui/company (2)
R7	Search and research ranking / validation	missed entity	Medium	backend/search (1), backend/research (2)
R8	Navigation shell	module unreachable	Medium	ui/navigation (2) — found IN:83
R9	Monitoring views	missed alert	Medium	ui/monitoring (1)
R10	Rate-limit contract	clients throttled unexpectedly	Low-Med	rate-limit decrement test

5. Coverage matrix (planned vs executed)

Project	Spec	Tests	Origin	Executed	Product defects
api	backend/health-and-auth	7	inherited api 1–4 + rate-limit	Yes	IN:81 (manual, /org)
api	backend/portfolio	4	inherited api 5–6 + pagination	Yes	—
api	backend/deals	4	new	Yes	—
api	backend/entities	3	inherited api 7–8 + new	Yes	—
api	backend/countries	3	inherited api 9 + new	Yes	—
api	backend/research	2	new	Yes	—
api	backend/search	1	inherited api 10	Yes	—
chromium	ui/auth	5	inherited ui 1–5	Yes	—
chromium	ui/navigation	2	inherited ui 6 + new	Yes	IN:83
chromium	ui/deal-book + deal-book-coverage	7	inherited ui 7 + new	Yes	—
chromium	ui/countries	4	inherited ui 8 + parity	Yes	—
chromium	ui/institutions + ui/company	3	inherited ui 9 + new	Yes	—
chromium	ui/portfolio	4	inherited ui 10 + new	Yes	IN:82
chromium	ui/monitoring	1	new (4 Nov product update)	Yes	—

Total	16 spec files	**50**	20 inherited + 30 new	50 / 50	3



6. Environments and configuration

Item	Value
CI	GitHub Actions, ubuntu-latest, Node 22, 2 workers
Local	Windows 10, Node 26
Framework	Playwright 1.64.1 (pinned), TypeScript strict, `npm run typecheck` gate in CI
Browser	Chromium (Desktop Chrome device), headless
playwright.config.ts	fullyParallel; retries 0; forbidOnly in CI; test timeout 60 s; expect timeout 10 s; baseURL from env; projects `api` and `chromium`
Secrets	`.env` locally (git-ignored); GitHub secrets STONEWAKE_EMAIL / PASSWORD / API_KEY scoped to the test and scan steps; credential scan of the HTML report before publishing

7. Test data, fixtures and cleanup

- Read-only suite: nothing is created, so nothing needs cleaning up and parallel runs cannot collide.
- Worker-scoped `config` validates the environment once. `api` / `anonApi` give authenticated and anonymous API facades. `loggedInApp` signs in once per worker through the page object, holds the session in memory and verifies the landing page before each test.
- Spec constants (e.g. search limit 25) live in `API_LIMITS`. Runtime data (first deal, first portfolio row) is read from the product, never hard-coded.

8. Execution and CI strategy

On push to `main` and on manual dispatch: `npm ci` → typecheck → browser install → `npx playwright test` (both projects) → credential scan of the report → artifact upload → publish to `gh-pages` under `runs/<n>/`. The published report carries a banner with the repository, run, commit and result. Concurrency queues runs instead of cancelling them, so a run is never silently dropped.

9. Flakiness controls

- Web-first assertions only (`toHaveURL`, `toBeVisible`, `toHaveText`, `toBeChecked`). All three fixed sleeps (`waitForTimeout`) were removed.
- Role / label / test-id locators owned by page objects, replacing XPath and CSS ids.
- One sign-in implementation instead of seven copies. Statuses are asserted before bodies are read, and `find()` results are guarded.

- Retries 0, so flakiness cannot hide behind a rerun. No `skip`, `fixme` or `only`, and no `continue-on-error`.

10. Entry and exit criteria

Entry: secrets present; typecheck clean; 50 tests discovered in two projects (24 api, 26 chromium).

Exit: five consecutive successful full-suite GitHub Actions runs on one commit with retries 0, 0 skipped, 0 flaky and a public report each. Every confirmed product defect is filed in SpiraTest. Residual risks are declared (§15).

Part B — Software Test Report (STR)

11. Execution summary

11.1 Before and after

Metric	Baseline (inherited, b4f92c9)	Final (certified, 6abf104)
Tests	20 (10 api + 10 ui)	50 (24 api + 26 ui)
Result	10 passed / 10 failed (deterministic, same 10 every run)	50 passed / 0 failed / 0 flaky / 0 skipped
Fixed sleeps	3	0
Retries	not set (Playwright default 0)	0 (explicit, policy)
Credentials	committed in .env and traces	injected from env / GitHub secrets; report scanned
Public report	none	GitHub Pages, one report per run

11.2 Five consecutive green runs (certification)

Commit `6abf1045a17023f50831fe2cf459b9ebd4cd0a15`. Scope: `npx playwright test`, both projects, 50 tests, retries 0, 2 workers, ubuntu-latest. Data read from the GitHub Actions API when this document was built (04 Nov 2026 20:30 Asia/Jerusalem). Nothing here is inferred.

#	Run	SHA	Started (UTC)	Finished (UTC)	Conclusion	Label
1	41882894791	6abf104	2026-11-04 18:01:38	2026-11-04 18:03:52	success	certification 1/5
2	41883315559	6abf104	2026-11-04 18:03:59	2026-11-04 18:06:40	success	certification 2/5
3	41883825380	6abf104	2026-11-04 18:06:48	2026-11-04 18:08:47	success	certification 3/5
4	41884232258	6abf104	2026-11-04 18:09:04	2026-11-04 18:11:58	success	certification 4/5
5	41884761006	6abf104	2026-11-04 18:12:08	2026-11-04 18:13:55	success	certification 5/5



Consecutive successful runs on this commit at build time: 5 of 5.

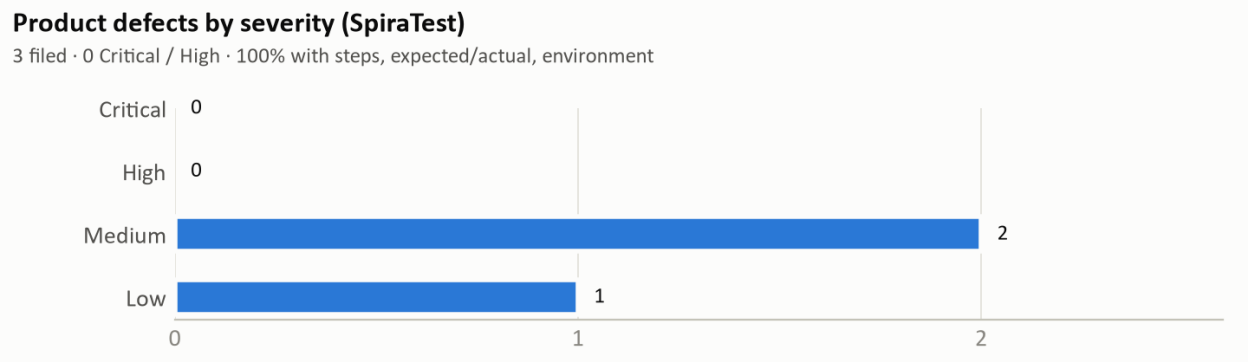
Note: the repository head is now `d58b82f`, later than the certified commit `6abf104`. The later commits change the CI workflow and make assertions stricter (still 50 tests). The five runs above certify `6abf104`.

12. Product defects (filed in SpiraTest)

All three are open (status New) in SpiraTest product 35. The SpiraTest links need a SpiraTest login. The Jam.dev link opens without one.

ID	Title	Area	Severity / Priority	Freq.	SpiraTest	Jam.dev
IN:81	/org/api-keys 401 responses reveal the refusal reason (two messages + undocumented `detail`), contradicting the uniform-refusal contract	API / Security	3 - Medium / 3 - Medium	100%	IN:81	Jam recording
IN:83	EDD Dossiers and Signals pages are reachable by URL but have no sidebar entry	UI / Navigation	3 - Medium / 3 - Medium	100%	IN:83	not recorded — evidence: automated test + Playwright trace
IN:82	Portfolio tile test id `tile-not_assessed` breaks the naming of the other four tiles	UI / Test hooks	4 - Low / 4 - Low	100%	IN:82	not recorded — evidence: DOM in CI trace artifact

12.1 Severity distribution and report quality



Quality metric	Count	Coverage
Bugs with ≥ 3 deterministic steps	3 / 3	100%
Bugs with expected and actual results	3 / 3	100%
Bugs with severity, priority, frequency, browser recorded	3 / 3	100%
Bugs with documentation basis for "expected"	3 / 3	100%
Bugs covered by the certified suite	2 / 3	67%: IN:83 has a dedicated test; IN:82's real tile id is asserted in ui/portfolio; IN:81 is left out of the certified suite (see below)
Bugs with a Jam.dev recording	1 / 3	33% (recording attempts for IN:82/83 did not start the tab capture)

12.2 Defect details

IN:81 — API key-management endpoint reveals why a credential was refused

- **Environment:** api.stonewake.ai 1.0.0, production, workspace itac-5; curl 8 on Windows 10 and Chrome through the API explorer (/docs).
- **Steps:** (1) Confirm a valid key: GET /v1/me with Bearer key → 200. (2) GET /org/api-keys with no Authorization header. (3) Same request with an invalid key. (4) Same request with the valid key. (5) Control: /v1/me with no header and with the invalid key.
- **Expected:** all three /org/api-keys calls return the single documented body {"error":{"code":"unauthenticated","message":"Missing or invalid credentials."}} with no extra fields (docs: errors, authentication, keys).
- **Actual:** "Missing bearer token" (no header) vs "Invalid or expired token" (invalid **and** valid key), plus an undocumented top-level `detail`. The /v1 control is correct.

- **Impact:** a documented security-posture promise is broken; a working key is called "invalid or expired", which misleads integrators into rotating it.
- **Evidence:** Jam.dev recording (credential masked); SpiraTest IN:81.
- **Automation:** the planned regression test API-AUTH-09 is left out of the certified suite rather than skipped or weakened, and that decision is disclosed here.

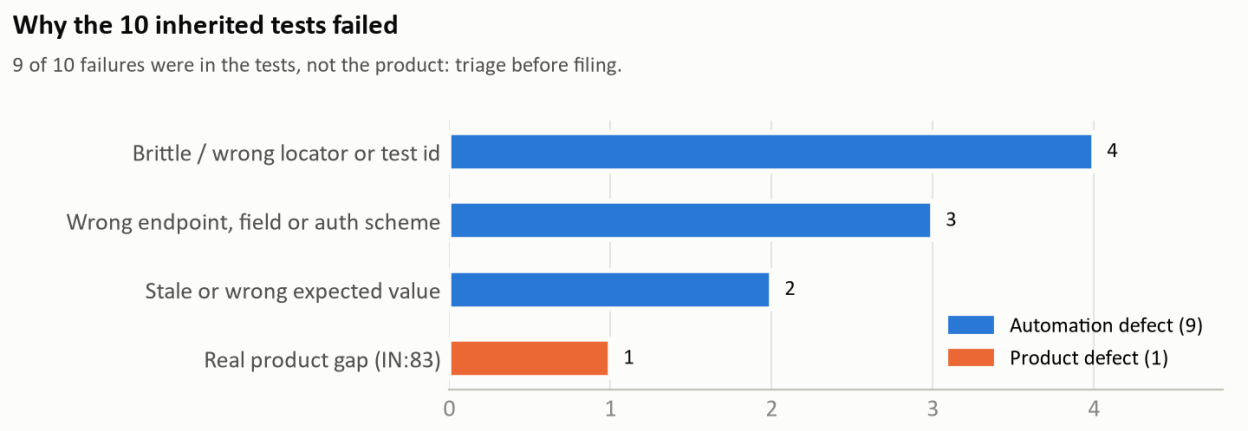
IN:83 — Enabled modules hidden from navigation

- **Environment:** app.stonewake.ai 1.0.0, Chromium (Playwright 1.64.1), Windows 10 and ubuntu-latest.
- **Steps:** (1) Sign in. (2) Read the sidebar links on Deal Book. (3) Open /dossiers and /signals directly.
- **Expected:** EDD Dossiers and Signals appear as sidebar entries, as the 4 Nov 2026 changelog states; the inherited test also clicked an "EDD Dossier" link.
- **Actual:** nine entries only. /dossiers and /signals render normally ("EDD Dossiers", "Signals"), so the modules are enabled but unreachable from the UI.
- **Impact:** users cannot discover two modules. No data loss.
- **Evidence:** automated test `navigation.spec.ts` › "EDD Dossiers and Signals pages exist by URL but are not linked from the sidebar"; SpiraTest IN:83.

IN:82 — Inconsistent portfolio tile test id

- **Steps:** sign in → /portfolio → read the data-testid of the five status tiles.
- **Expected:** one naming rule (e.g. tile-not-assessed). **Actual:** tile-red, tile-amber, tile-green, tile-insufficient, **tile-not_assessed**. No tile exists for the sixth API status `sole_trader`.
- **Impact:** no end-user impact; it caused a real automation failure (inherited ui 10) and will mislead integrators.
- **Evidence:** DOM snapshot in the Playwright trace of the baseline run (Actions artifact); SpiraTest IN:82.

13. Automation defects found and fixed (not product bugs)



Inherited test	Observed	Root cause	Fix
api 1 health	/v1/health → 404	wrong path	/health
api 2 me	Token scheme → 401	wrong auth scheme	Bearer via one ApiClient; removed console.log of account data
api 5 portfolio	body has `items`, test read `data`	wrong field	typed PageOf<T>, assert `items`
api 9 countries	DEU iso2 is DE; test expected GE	wrong expected value	DE + find() guard (negative control proves it can fail)
api 10 search	max limit 25 per OpenAPI; test expected 50	stale expectation	bound from API_LIMITS
ui 1 login	no #email element	brittle id selector + 2 s sleep	getByRole('textbox', {name:'Email'}), toHaveURL
ui 3 terms	native checkbox is aria-hidden	wrong element	role=checkbox + toBeChecked
ui 6 sidebar	no "EDD Dossier" link	**product (IN:83)**	nine modules + URL test for /dossiers and

			/signals
ui 7 deal book	links are /deals/<id>	wrong href + 3 s sleep	/deals/, web-first waits
ui 10 portfolio	id is tile-not_assessed	wrong test id (+ IN:82)	real id

No inherited assertion was weakened: 20 of 20 tests are traced, assertion counts are equal or higher, and the full table is in docs/DEFECTS_AND_CHANGES.md §3.

14. Observations not filed (and why)

Observation	Decision
Deal names / legal_form_label looked garbled ("mojibake") in the API	**Disproved**: a probe decoding error; the raw bytes are valid UTF-8. Not filed.
Portfolio row link appends ?from=portfolio	Informational, by design.
Unscored Portfolio Score cells are visually empty ("Not scored" only in aria-label/title)	Cosmetic / unspecified. Candidate for an accessibility review.
Deal names use ", " in the UI and " - " in the API	Unspecified formatting difference. Parity tests normalise it.
Germany shows 5 risk breakdown rows vs 7 in the API	By design: the page prints only components that have data.

15. Insights

- **Most "failures" were not bugs.** Ten of ten inherited failures came from the tests, not the product. Triaging each one against the docs and live behaviour before filing kept SpiraTest free of false positives. Only one of the ten (ui 6) pointed at a real product gap.
- **The highest-value bug came from comparing docs with behaviour on a less-travelled endpoint.** /v1 honours the uniform-refusal contract; /org/api-keys, a different service surface, does not. Security contracts should be tested on every surface, not just the main API.
- **Release notes drift from the deployed product.** The 4 Nov changelog promises sidebar entries that are missing (IN:83). Checking the changelog against the build is a cheap source of real defects.
- **Parity tests add a different kind of coverage.** Reading a record from the API and asserting the dashboard shows the same value catches data-binding defects that neither layer finds alone. They also bring a declared risk: live data can refresh between the two reads.
- **Test hooks are a product interface.** An inconsistent data-testid (IN:82) broke automation. Hooks deserve the same naming review as public APIs.
- **Stability came from removing guesswork, not adding retries.** Removing the sleeps, using semantic locators, signing in once and asserting web-first made the suite deterministic with retries 0. Five green in a row is believable only because nothing was retried, skipped or weakened.
- **Evidence hygiene matters.** A Jam recording first exposed a full API key in Swagger's curl panel. It was deleted and re-recorded with the panel hidden. Recordings and traces must be reviewed before they are shared.

16. Residual risks, limitations and next steps

- The inherited repository history contains a .env and traces with real credentials. History was not rewritten (provenance), and rotation has been requested from the organizers.
- Live shared data: parity tests can fail if data refreshes between the API and UI reads. That would be real drift, and it is declared rather than masked.
- First-row dependence in some tests (top deal, first company). Branches that did not execute on today's data are not claimed as verified.
- Chromium only. MCP, the network graph, UI writes, accessibility and visual testing are not covered.
- Next coverage, in priority order: /org/api-keys contract test (once IN:81 is fixed), screenings with sources, ownership chain via the API, deal export content-type and size, MCP tools/list, an axe-core smoke test on login and Deal Book.

17. Evidence and references

- Repository: https://github.com/meyuval/itac-finals · Actions: https://github.com/meyuval/itac-finals/actions · Report: https://meyuval.github.io/itac-finals/
- In the repository: docs/STP.md, docs/DEFECTS_AND_CHANGES.md (root causes, traceability, assertion counts), .itac/FIVE_GREEN.md, .itac/baseline/ (baseline logs, negative control), docs/AI_USAGE.md.
- SpiraTest: IN:81, IN:82, IN:83 · Jam.dev: https://jam.dev/c/ec59a5c7-7b62-4431-ad46-8dbd12b42303